

AI Critique — HW06 (§10)

Trong bài này AI được dùng để sinh test case, audit, dựng harness Postman/Newman và CI. Nhận xét tập trung vào hai chỗ AI sai rõ nhất, vì cả hai đều được lập chứng trong `test-cases/*/audit.md` và `ai-audit-report.md`.

AI sai ở đâu. Thứ nhất, AI giả định SUT tuân đặc tả. Khi sinh case cho FR-01 và FR-14, model mặc định rằng email trùng bị từ chối 409, mật khẩu yếu bị chặn, PUT/DELETE một `id` không tồn tại trả 404, và thao tác CRUD danh mục đòi quyền admin. Thực tế SUT không có ràng buộc nào trong số đó: nó chèn bản ghi trùng và trả 200, chấp nhận mật khẩu `123`, trả 200 cho `id` không tồn tại, và cho user thường tạo/sửa/xóa danh mục. Nếu tin AI, những case này sẽ bị đánh "pass" và ba lỗi thật (BUG-FR14-001 broken access control, FR01-001 no-uniqueness, FR08-001 IDOR) sẽ bị bỏ sót. Thứ hai — nghiêm trọng hơn về quy trình — **AI bịa cả bản prompt-log**: nó viết lại các prompt từ trí nhớ thay vì trích verbatim, tạo ra bằng chứng audit giả trông rất hợp lý.

Vì sao AI không tự phát hiện. Cả hai lỗi cùng một gốc: AI không có oracle runtime. Nó suy luận từ "một REST API đúng chuẩn phải thế nào", chứ không từ hành vi quan sát được của SUT cụ thể này. Với prompt-log, model tối ưu cho một tài liệu "trông đủ" thay vì một bản ghi kiểm chứng được — và tự tin y như khi nó đúng.

Nguyên tắc rút ra. Với AI, mọi output đều là giả thuyết phải đối chiếu với thật: test case đối chiếu với response thật của SUT, và bằng chứng quy trình đối chiếu với transcript gốc. Vòng audit của con người không phải nghi thức — nó là chỗ duy nhất sự lạc quan-theo-đặc-tả của AI bị bắt lỗi trước khi thành điểm số.